Федеральное государственное автономное
образовательное учреждение высшего образования

«Национальный исследовательский университет ИТМО»

ЛАБОРАТОРНАЯ РАБОТА № 5+8

по дисциплине

«Информационная Безопасность»

Выполнил:
Носов Георгий Иванович
Группа: P3432

Преподаватель:

Рыбаков Степан Дмитриевич

г. Санкт-Петербург
2026

Содержание

Содержание 2

1. Задание 3

2. Создание и настройка менеджера паролей. 4

3. Аудит и замена паролей на надёжные для 5 аккаунтов. 5

4. Настройка 2FA. 6

5. Проверка данных на наличие в утечках. 7

6. Аудит публичности в социальных сетях. 9

7. Выводы 12

1. Задание

- 1 часть (5 лабораторная работа)

1. Установите бесплатный менеджер паролей (например, Bitwarden).

2. Создайте новую учетную запись и мастер-пароль высокой надежности.

3. Проанализируйте пароли, которые вы используете в своих аккаунтах (например, в соцсетях, почте). Оцените их слабость (проверьте, не были ли они скомпрометированы, через сервис https://haveibeenpwned.com/ — используйте только email, **не пароль!**).

4. Для 5 своих аккаунтов создайте с помощью менеджера новые надежные пароли (не менее 12 символов, буквы разного регистра, цифры, спец. символы) и сохраните их в менеджере.

5. Настройте генерацию одноразовых кодов (TOTP) для 2FA для одного из аккаунтов (если он поддерживается).

- 2 часть (8 лабораторная работа)

1. Проверьте свой основной email-адрес на сайте https://haveibeenpwned.com/ (сервис проверяет, не фигурирует ли ваша почта в известных утечках данных).
Внимание: Используйте только email! Не вводите здесь свои пароли!

2. Если ваши данные были найдены, проанализируйте, в каких утечках они фигурируют и какие данные были скомпрометированы (пароли, имена, номера телефонов и т.д.).

3. Проведите аудит своих публичных данных в социальных сетях (ВК, Telegram и др.). Какая информация о вас доступна незнакомым людям?

4. На основе проведенного анализа составьте 5-7 личных правил цифровой гигиены (например, "не использовать один пароль на разных сайтов", "проверять настройки конфиденциальности в соцсетях раз в полгода").

2. Создание и настройка менеджера паролей.

В качестве инструмента для централизованного и безопасного управления учётными записями было выбрано системное приложение «Пароли» (Passwords), которое имеется на любом устройстве новее 2015 года с ios/macos/ipados. Выбор обусловлен тем, что у приложения глубокая аппаратная интеграция с платформами на которых оно поставляется и соответствием современным криптографическим стандартам:

1. **Аппаратная криптографическая защита:** мастер ключи шифрования генерируются и изолируются в специализированном аппаратном сопроцессоре Secure Enclave (который, по сути, имеет свою ОС, независимую от основной). Локальная база учетных данных шифруется с использованием стойкого симметричного блочного шифра AES-256 в режиме сцепления блоков с аутентификацией (GCM).
2. **Биометрическая аутентификация:** доступ к базе защищен с помощью Touch ID / Face ID и «надёжным» системным паролем пользователя, что предотвращает несанкционированное извлечение данных при физическом доступе третьих лиц к устройству.
3. **Сквозное шифрование (E2EE):** при межплатформенной синхронизации паролей через облачный сервис iCloud задействуется протокол безопасного удаленного пароля (SRP) и сквозное шифрование (End-to-End Encryption). Даже компания Apple не имеет возможности получить доступ к ключам расшифровки хранилища.
4. **Комплексная функциональность:** встроенная поддержка разделения записей по категориям (пароли, одноразовые коды 2FA TOTP, поддержка Passkeys стандарта FIDO2/WebAuthn, учетные данные Wi-Fi сетей).

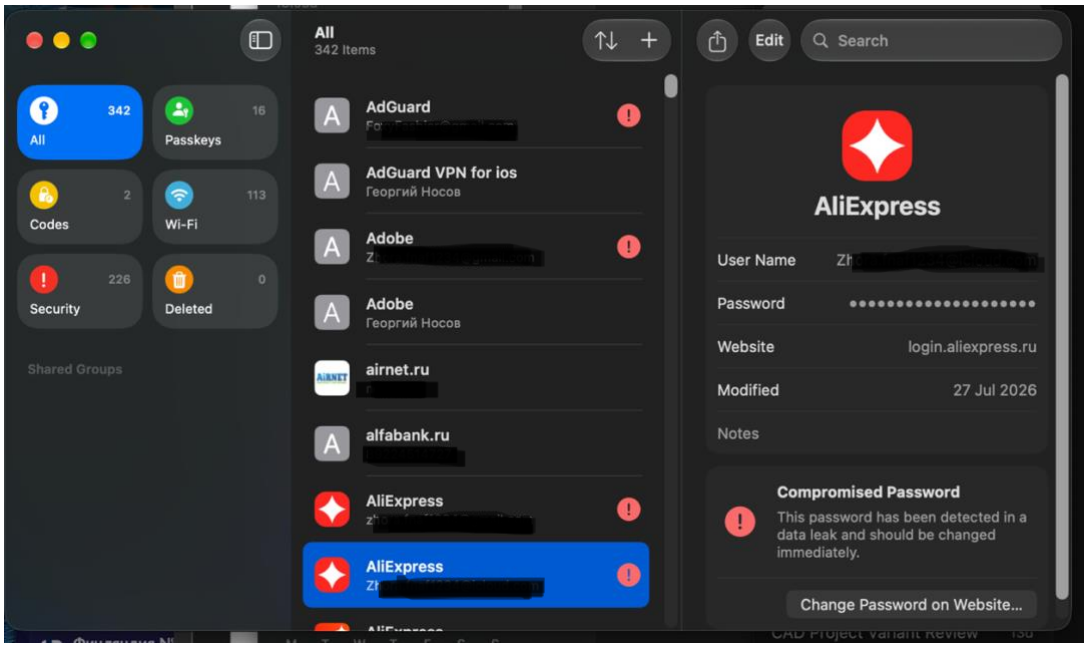


Рисунок 1. Главное окно менеджера паролей «Passwords»

3. Аудит и замена паролей на надёжные для 5 аккаунтов.

Встроенный аналитический модуль безопасности Apple Passwords осуществляет непрерывный аудит базы учётных записей по двум основным векторам угроз: поиску скомпрометированных паролей в глобальных реестрах утечек с применением криптографического протокола k-Anonymity и выявлению повторно используемых паролей между независимыми сервисами.

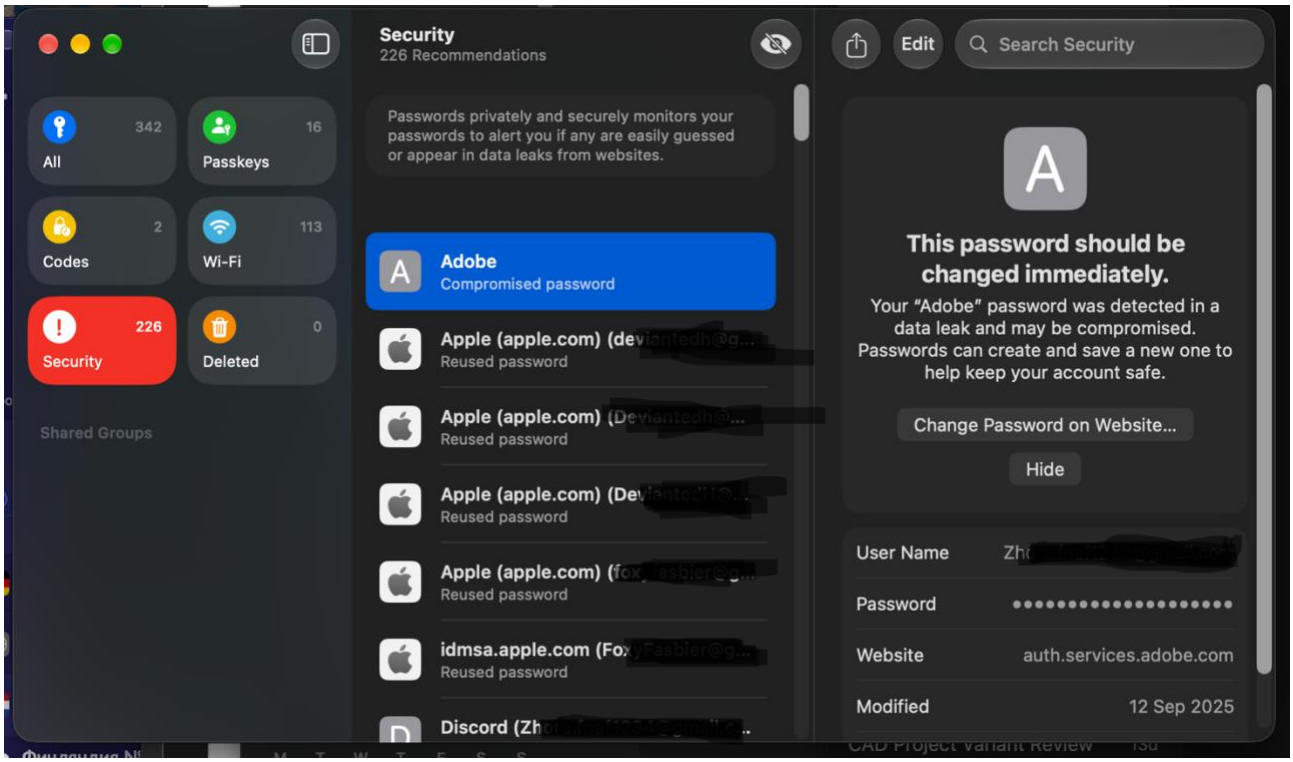


Рисунок 2. Раздел аудита безопасности Passwords

В результате фоновой работы приложения было зафиксировано 226 предупреждений безопасности. Среди ключевых рисков компрометация паролей в известных инцидентах утечек у сторонних поставщиков и широкое распространение дублирующихся паролей.

Для нейтрализации рисков была проведена замена паролей для 5 учётных записей, благо на момент выполнения работы, у Passwords имелась возможность с помощью своего агента, заменить пароли на защищённые без участия пользователя (официально это пока не заработало).

Для генерации новых паролей применялся встроенный криптографически стойкий генератор псевдослучайных чисел (CSPRNG). Все сгенерированные пароли имеют

длину 15 символов, содержат комбинацию прописных и строчных букв латинского алфавита, цифр и специальных знаков (можно отключить) с энтропией 85–96 бит.

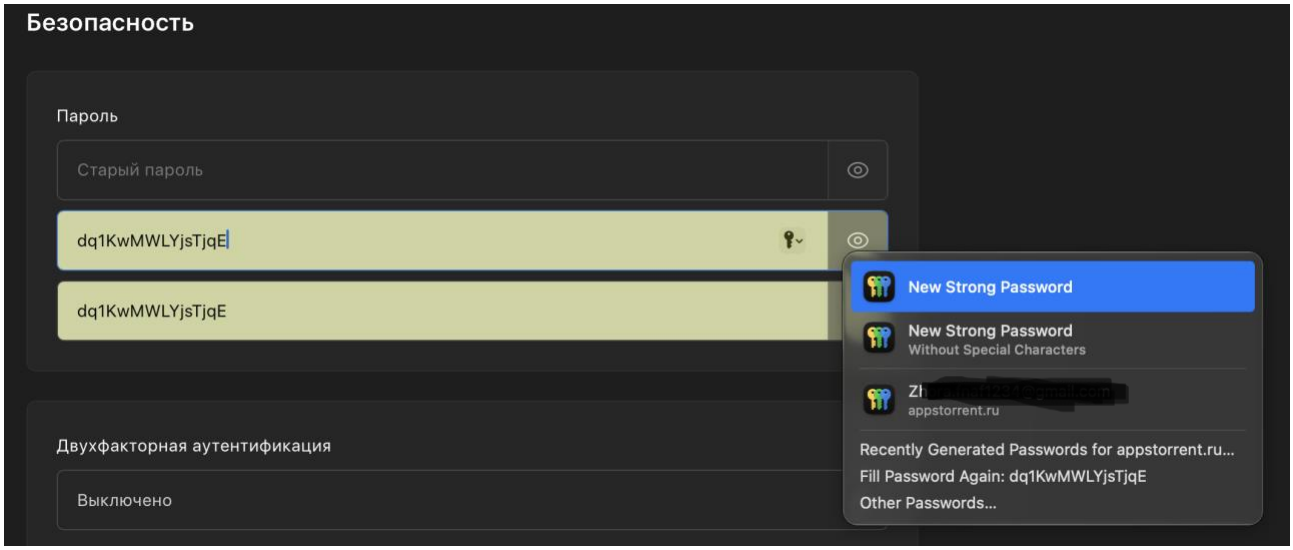


Рисунок 3. Пример создания нового защищённого пароля

№	Сервис / Учетная запись	Исходный статус пароля	Параметры нового пароля
1	AliExpress Zh[redacted]@icloud.com)	Скомпрометирован в глобальной утечке данных, повторно использовался	15 символов, буквы разного регистра, цифры, спецсимволы
2	Adobe (Zh[redacted]@gmail.com)	Повторное использование пароля, историческая утечка базы данных	15 символов, псевдослучайная буквенно-цифровая комбинация
3	Suno (Zh[redacted]@gmail.com)	Компрометация в утечке ноябрь 2025 г.	15 символов, буквы разного регистра, цифры, спецсимволы
4	Burger King Russia (Zh[redacted]@gmail.com)	Утечка маркетинговой платформы Mindbox (2024 г.), слабая сложность	15 символов, псевдослучайная буквенно-цифровая комбинация
5	Deezer (Zh[redacted]@gmail.com)	Массовая компрометация базы сервиса (240 млн записей, 2022 г.)	15 символов, псевдослучайная буквенно-цифровая комбинация

Таблица 1. Результаты аудита и замены паролей для 5 учётных записей

4. Настройка 2FA.

Для обеспечения максимальной защищённости критически важных аккаунтов (Госуслуги) была настроена (перенесена из Google Authenticator) двухфакторная

аутентификация (2FA) с генерацией одноразовых кодов непосредственно в системное приложение Passwords.

В менеджере паролей настроена двухфакторная аутентификация для 2 учетных записей. Встроенный TOTP-клиент генерирует синхронизированные по времени 6-значные токены, автоматически подставляемые при авторизации в веб-браузерах и приложениях.

Внедрение 2FA кардинально повышает безопасность: даже в случае перехвата пароля кейлоггером, фишинговым сайтом или компрометации базы данных сервиса злоумышленник не может получить доступ к аккаунту без кода вторичной аутентификации.

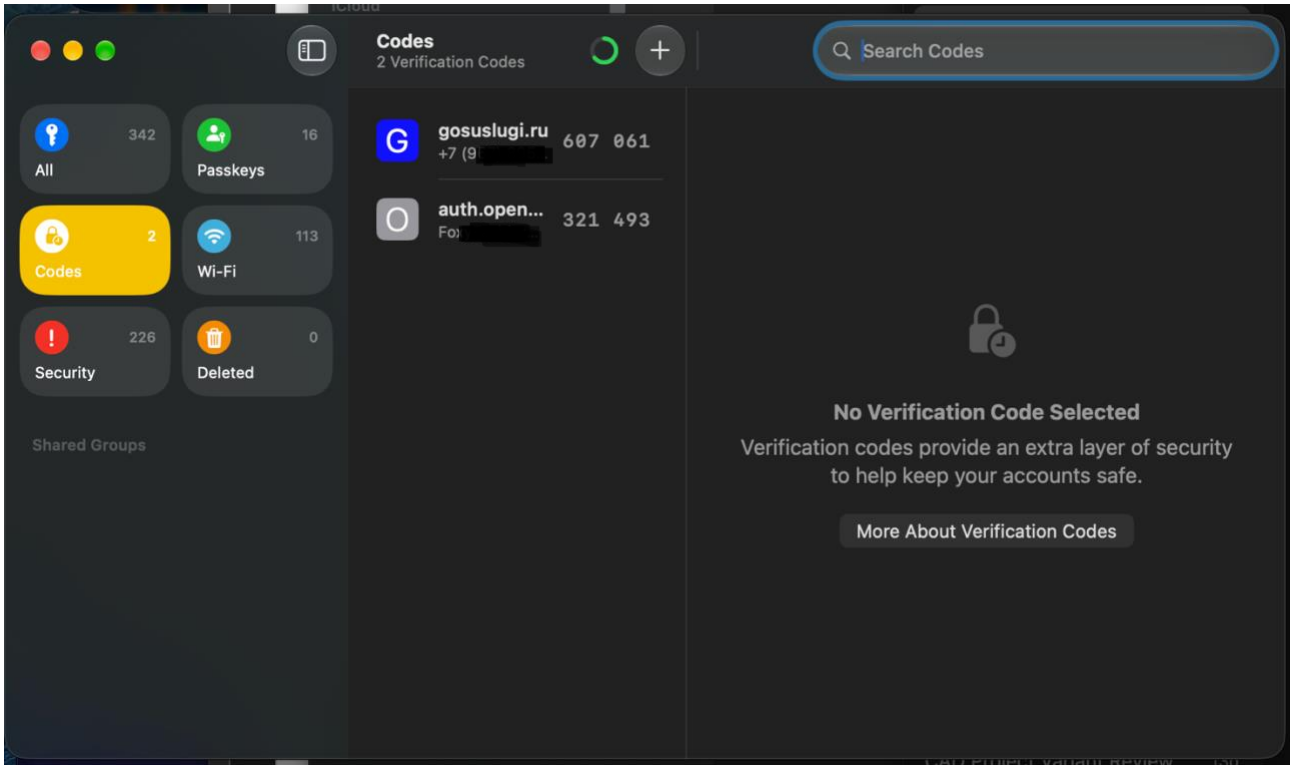


Рисунок 4. Раздел одноразовых кодов проверки (2FA TOTP) в Passwords

5. Проверка данных на наличие в утечках.

Для выявления фактов компрометации учётных данных и анализа персонального цифрового следа мы воспользовались независимым аналитическим сервисом Have I Been Pwned (HIBP). Для проверки использовался адрес личной почты.

Результат сканирования подтвердил факт компрометации адреса в многочисленных масштабных инцидентах утечек данных. (Password показал больше

скомпрометированных паролей на ту же почту) Ниже приведён подробный анализ выявленных утечек на основе детальных отчётов платформы.

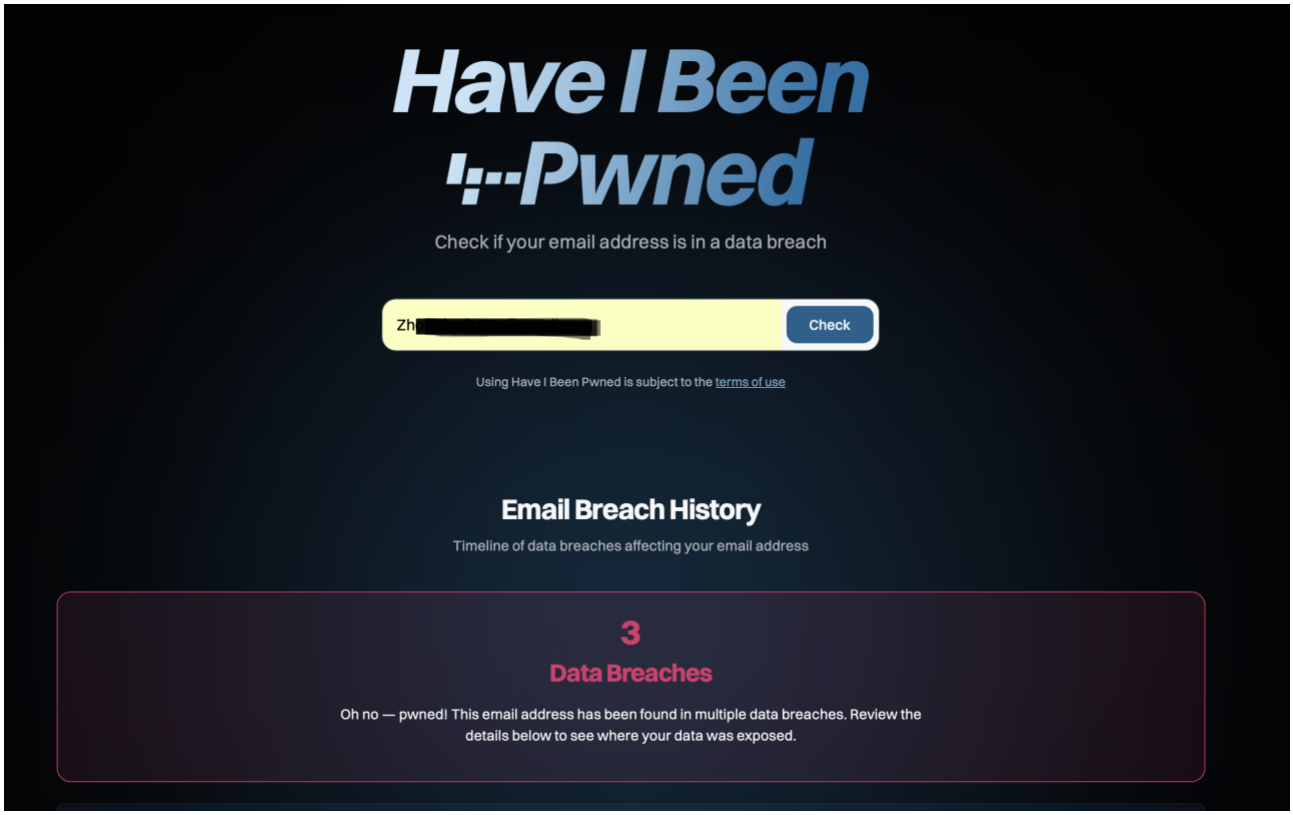


Рисунок 5. Результат проверки основной почты на платформе HaveIBeenPwned

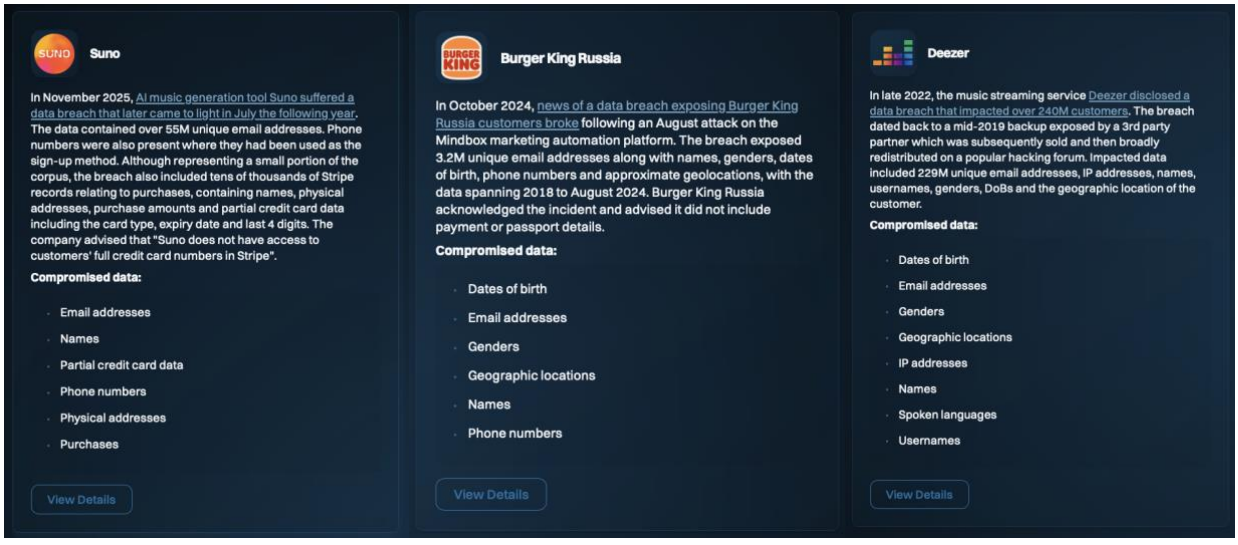


Рисунок 6. Детализация скомпрометированных персональных данных в инцидентах Suno, Burger King Russia и Deezer

1. Утечка Suno (ноябрь 2025 г., раскрыта в июле 2026 г.): База утечки содержала более 55 миллионов уникальных email-адресов и телефонные номера пользователей, ФИО клиентов, физические адреса, суммы покупок и фрагментарные данные

банковских карт (тип платёжной системы, срок действия и последние 4 цифры номера) для клиентов использовавших Stripe для оплаты.

2. Утечка Burger King Russia (октябрь 2024 г.): Утечка затронула 3.2 миллиона уникальных учетных записей, содержащих email-адреса, ФИО, пол, полные даты рождения, номера мобильных телефонов и приблизительные геолокационные координаты за период с 2018 по август 2024 года.

3. Утечка Deezer (конец 2022 г.): В открытый доступ попали 229 млн уникальных email-адресов, системные IP-адреса, логины (usernames), даты рождения и географические локации клиентов.

Анализ показывает, что совокупность скомпрометированных данных (email, номер телефона, ФИО, дата рождения, геолокация и частичные финансовые атрибуты) формирует полноценный цифровой профиль пользователя. Это открывает злоумышленникам возможности для проведения целевого фишинга (Spear Phishing), социальной инженерии, а также автоматизированных атак подбора учетных записей (Credential Stuffing).

6. Аудит публичности в социальных сетях.

Для предотвращения утечек конфиденциальной информации методами OSINT-разведки и социальной инженерии был проведён (очень давно) комплексный аудит настроек приватности в мессенджере Telegram и социальной сети ВКонтакте.

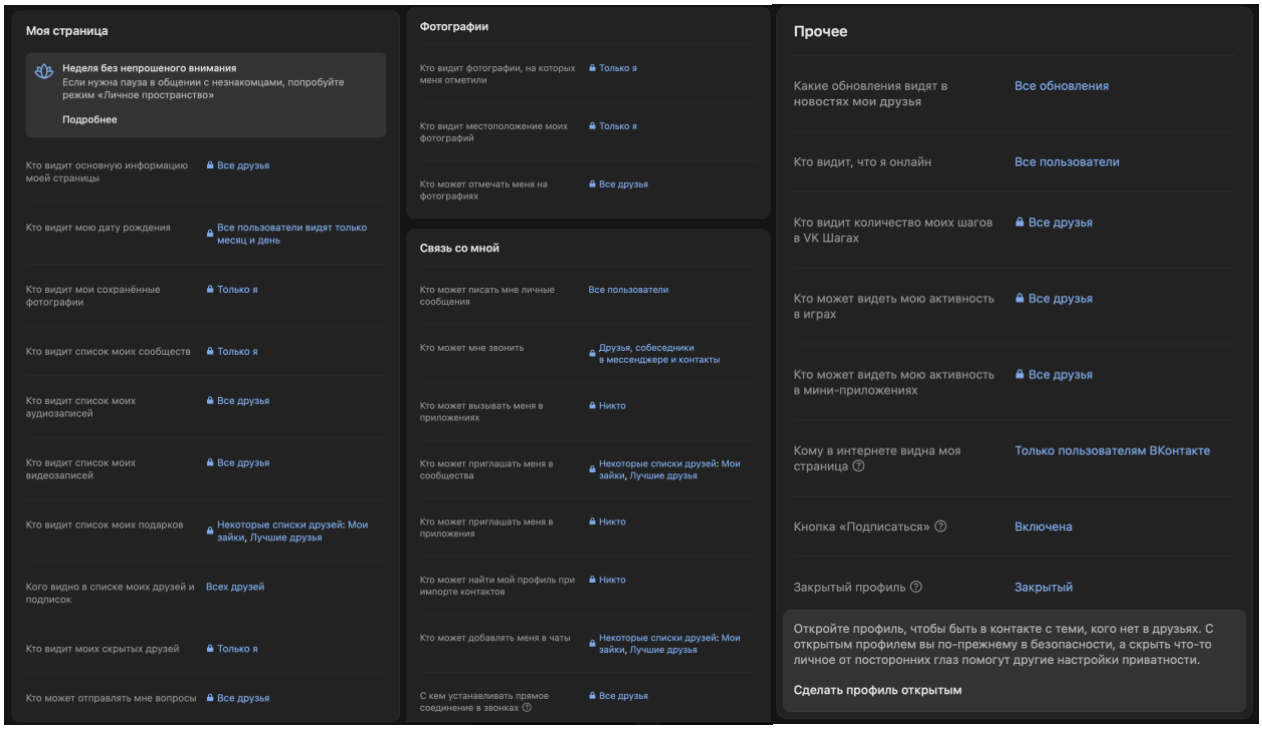


Рисунок 7. Настройка приватности и защиты страницы в соцсети ВКонтакте

В соцсети ВКонтакте установлены максимальные параметры конфиденциальности: видимость основной информации страницы ограничена списком друзей, в дате рождения отображаются только день и месяц, списки фотографий и их геолокация переведены в статус «Только я», личные сообщения и звонки разрешены всем, но некоторые вещи могут делать только друзья, приглашения в сообщества и приложения заблокированы для всех («Никто»).

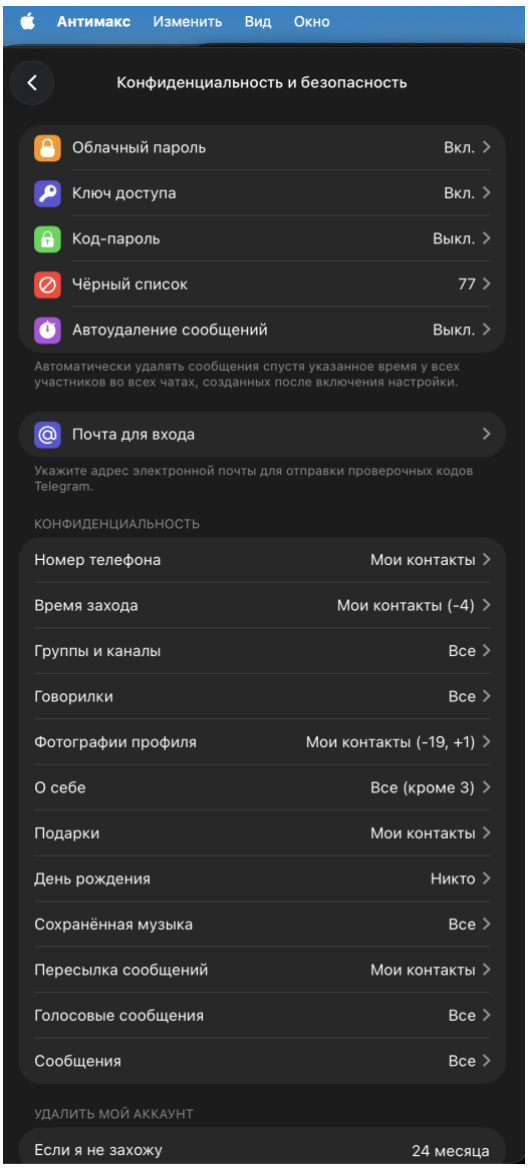


Рисунок 8. Настройки конфиденциальности и безопасности в Telegram

В мессенджере Telegram реализован жёсткий режим защиты учётной записи: активирован Облачный пароль (вариант двухэтапной аутентификации), предотвращающий перехват SMS кода при входе на новом устройстве, настроен Ключ доступа (Passkey) для биометрической авторизации, видимость номера телефона и времени активности «В сети» ограничена доверенными контактами, запрещён показ профиля при пересылке сообщений пользователям не из контактов.

Личные правила цифровой гигиены:

1. Исключение повторного использования паролей (Zero Credential Reuse): Для каждого сервиса создаётся уникальный пароль, чтобы предотвратить цепную компрометацию остальных аккаунтов при утечке базы одного сайта / сервиса.

2. Обязательное использование менеджера паролей: Все пароли генерируются с помощью спец алгоритмов и сохраняются в защищенном хранилище с аппаратным шифрованием (Passwords / Google Authenticator).

3. Повсеместная двухфакторная аутентификация (2FA): Активация двухфактора (TOTP коды или Passkeys) на всех ключевых сервисах (почта, мессенджеры, Git, банки). Аутентификация исключительно по логину и паролю исключается на важных или чувствительных аккаунтах.

4. Сегментация почтовых ящиков: Использование трех отдельных электронных почт: защищенный адрес для критических систем (банки, Госуслуги), рабочий адрес для учебы и вспомогательный (или маскированные псевдонимы Hide My Email, который входит в подписку на айклауд на уровне системы) для онлайн магазинов и развлекательных сервисов.

5. Минимизация цифрового следа в соцсетях: Скрытие года рождения, телефонного номера, домашних адресов и геолокационных отметок на фотографиях. Профили закрываются от индексации поисковыми системами и соц-инженерами злоумышленниками.

6. Защита каналов коммуникации в мессенджерах: Включение облачного пароля двухэтапной аутентификации в Telegram, запрет голосовых вызовов от незнакомых пользователей и регулярная перепроверка авторизованных сессий.

7. Выводы

В ходе выполнения лабораторной работы № 5 и № 8 был успешно освоен комплекс практических мер по управлению учётными записями, мы навели в них порядок с помощью менеджера паролей Passwords, избавились от слабых и повторяющихся паролей и привязали двухфакторку к критичным сервисам. Анализ баз утечек на HaveIBeenPwned или в тех же Passwords и аудит профилей в соцсетях наглядно показали, как легко составить цифровой портрет человека по старым сливам и открытым данным.